

MARCO INTEGRATIVO GQM + PRAGMATIC PARA INDICADORES MSS

Desde los Objetivos Nacionales hasta las Métricas Técnicas

Versión 1.0 — Abril 2026

"La métrica sin propósito es numerología. El propósito sin métrica es retórica. GQM es el puente; PRAGMATIC, el filtro."

1. FUNDAMENTO DEL MARCO: GQM Y PRAGMATIC AL SERVICIO DE LOS MSS

1.1. Goal-Question-Metric (GQM)

El método **GQM (Goal-Question-Metric)**, propuesto inicialmente por Basili y Weiss y ampliamente utilizado en ingeniería del software, define un modelo de medida en tres niveles jerárquicos[cite:129][cite:138][cite:141]:

1. Nivel conceptual (Goal – Objetivo):
2. Formulación explícita de un objetivo de medición, aplicado a un objeto (producto, proceso, servicio), con una motivación y un punto de vista determinados, en un contexto específico.
3. Nivel operativo (Question – Pregunta):
4. Conjunto de preguntas que caracterizan el grado de consecución del objetivo y que ayudan a entender el objeto desde diferentes perspectivas.
5. Nivel cuantitativo (Metric – Métrica):
6. Conjunto de métricas asociadas a cada pregunta, que permiten responderla de forma cuantificable.

En ciberseguridad, GQM se ha adoptado para alinear métricas técnicas con objetivos de negocio y de riesgo, evitando el síndrome de "dashboard ornamental" en el que se miden hechos curiosos pero irrelevantes[cite:134].

1.2. El Metamarco PRAGMATIC

El enfoque **PRAGMATIC Security Metrics**, propuesto por Brotby e Hinson, introduce un metamarco para evaluar la calidad de las métricas de seguridad, utilizando nueve criterios representados por el acrónimo PRAGMATIC[cite:130][cite:131][cite:136][cite:139]:

- P — Predictive (Predictivo): Indica algo útil sobre el futuro antes de que ocurra.
- R — Relevant (Relevante): Relacionado con las decisiones y objetivos del público destinatario.
- A — Actionable (Accionable): Sugiere claramente qué acciones emprender.
- G — Genuine (Genuino): Basado en datos fiables, sin manipulación interesada.
- M — Meaningful (Significativo): Fácil de entender e interpretar correctamente.
- A — Accurate (Preciso): Suficientemente exacto para la decisión que soporta.
- T — Timely (Oportuno): Disponible dentro de la ventana temporal de decisión.
- I — Independent (Independiente): No distorsionado por incentivos o conflictos.
- C — Cheap (Rentable/Barato): Coste de obtención y mantenimiento razonable.

Cada métrica candidata se puntúa habitualmente de 0 a 10 en cada criterio, obteniendo un "metapuntuación" PRAGMATIC que permite comparar y seleccionar aquellas métricas que realmente merecen un lugar en el cuadro de mando[cite:130][cite:136].

2. OBJETIVOS NACIONALES Y ESTRATÉGICOS (GOALS NIVEL 0)

Los objetivos de alto nivel que motivan el diseño de indicadores MSS en el contexto español y europeo se derivan de:

- Directiva NIS2 (UE 2022/2555): Garantizar un elevado nivel común de ciberseguridad, mediante gestión de riesgos, notificación de incidentes y seguridad de la cadena de suministro.
- ENS (RD 311/2022): Asegurar la protección adecuada de la información y los servicios en el sector público y sus proveedores.
- DORA (UE 2022/2554): Asegurar la resiliencia operativa digital del sector financiero frente a incidentes TIC.
- Plan Nacional de Ciberseguridad y plan de inversión de 1.157 M€ (2025): Reforzar las capacidades nacionales de prevención, detección, respuesta y recuperación ante ciberamenazas.
- **Estrategias sectoriales (SNS, energía, transporte, etc.).

A partir de estos marcos, se definen cinco **Objetivos Estratégicos G0.x** que articulan el marco GQM:

- G0.1 — Gobernanza y alineación estratégica:
 - Lograr una gobernanza de ciberseguridad que integre la toma de decisiones de la Alta Dirección, cumpla NIS2/ENS/DORA y asigne recursos proporcionales al riesgo.
- G0.2 — Detección y respuesta eficaces:
 - Reducir drásticamente el tiempo de detección, contención y recuperación de incidentes en comparación con la velocidad de los atacantes y los plazos regulatorios.
- G0.3 — Cumplimiento regulatorio demostrable:
 - Demostrar de forma objetiva y trazable el cumplimiento con NIS2, ENS, DORA, ISO 27001 y otros marcos relevantes.
- G0.4 — Resiliencia operativa y continuidad:
 - Garantizar la continuidad de los servicios críticos ante incidentes severos, minimizando el impacto en ciudadanos, clientes y economía.
- G0.5 — Innovación segura y preparación para amenazas emergentes:
 - Asegurar que la adopción de IA, cloud, OT/ICS y criptografía postcuántica se realiza con métricas que capturen los nuevos riesgos asociados.

3. DESPLIEGUE GQM POR PILARES E INDICADORES CLAVE MSS

A continuación se presenta el despliegue GQM para los indicadores clave de MSS identificados en el informe "MSS". Para cada indicador se define:

- Goal (G): Objetivo específico asociado al indicador.
- Questions (Q): Preguntas que concretan si el objetivo se cumple.
- Metric (M): Métrica concreta (o conjunto de métricas) que responde a las preguntas.

3.1. Pilar Detección y Respuesta — MTTD, MTTC, MTTR, FPR

3.1.1. MTTD — Mean Time to Detect

- G-DR1 (Objetivo):
 - Reducir el tiempo medio de detección de incidentes críticos hasta un valor compatible con la ventana de notificación NIS2 (24h) y con la velocidad operativa de los atacantes.
- Q-DR1.1: ¿En cuánto tiempo se detectan actualmente los incidentes críticos desde el inicio de la actividad maliciosa?
- Q-DR1.2: ¿Cuál es la tendencia del MTTD en los últimos 12 meses (mejora, empeora, estancado)?
- Q-DR1.3: ¿Existen diferencias significativas de MTTD entre tipos de incidente (ransomware, DDoS, exfiltración)?
- Métricas (M-DR1.x):
 - M-DR1.1: MTTD medio (en minutos/horas) para incidentes de severidad ALTA/CRÍTICA.
 - M-DR1.2: Distribución de MTTD (percentiles 50, 75, 90).
 - M-DR1.3: MTTD por tipo de incidente (categorías ENISA Threat Landscape).
 - M-DR1.4: MTTD máximo registrado en el último año (outliers).

Reducir el tiempo medio de detección de incidentes críticos hasta un valor compatible con la ventana de notificación NIS2 (24h) y con la velocidad operativa de los atacantes.

Q-DR1.1: ¿En cuánto tiempo se detectan actualmente los incidentes críticos desde el inicio de la actividad maliciosa?

Q-DR1.3: ¿Existen diferencias significativas de MTTD entre tipos de incidente (ransomware, DDoS, exfiltración)?

Métricas (M-DR1.x):

3.1.2. MTTC — Mean Time to Contain

- - G-DR2: Limitar el "blast radius" de los incidentes reduciendo el tiempo medio de contención hasta niveles que impidan el movimiento lateral significativo y la exfiltración masiva.
- - Q-DR2.1: ¿Cuánto tiempo transcurre de media entre la detección y la contención efectiva del incidente?
- - Q-DR2.2: ¿Qué porcentaje de incidentes críticos se contiene dentro del umbral definido en el SLA MSS?
- - Métricas:
 - M-DR2.1: MTTC medio (minutos/horas) incidentes críticos.
 - M-DR2.2: % de incidentes contenidos dentro del SLA (p.ej. <4h).

G-DR2: *Limitar el "blast radius" de los incidentes reduciendo el tiempo medio de contención hasta niveles que impidan el movimiento lateral significativo y la exfiltración masiva.*

Q-DR2.1: ¿Cuánto tiempo transcurre de media entre la detección y la contención efectiva del incidente?

Q-DR2.2: ¿Qué porcentaje de incidentes críticos se contiene dentro del umbral definido en el SLA MSS?

Métricas:

3.1.3. MTTR — Mean Time to Respond/Recover

- G-DR3: Minimizar el tiempo de restauración segura de servicios críticos tras incidentes significativos, de modo que el impacto en negocio se mantenga dentro del apetito de riesgo aprobado.
- Q-DR3.1: ¿Cuál es el tiempo medio de recuperación para incidentes críticos?
- Q-DR3.2: ¿Qué porcentaje de incidentes críticos se resuelven dentro de los objetivos RTO definidos en el BCP?
- Métricas:
 - M-DR3.1: MTTR medio (horas/días) para incidentes críticos.
 - M-DR3.2: % de incidentes en los que se cumple RTO.

G-DR3: *Minimizar el tiempo de restauración segura de servicios críticos tras incidentes significativos, de modo que el impacto en negocio se mantenga dentro del apetito de riesgo aprobado.*

Q-DR3.1: ¿Cuál es el tiempo medio de recuperación para incidentes críticos?

Q-DR3.2: ¿Qué porcentaje de incidentes críticos se resuelven dentro de los objetivos RTO definidos en el BCP?

Métricas:

3.1.4. FPR — False Positive Rate

- G-DR4: Reducir la tasa de falsos positivos a un nivel que no genere fatiga de analistas ni oculte incidentes reales.
- Q-DR4.1: ¿Qué porcentaje de alertas analizadas resulta ser falso positivo?
- Q-DR4.2: ¿Cuál es la tendencia trimestral de la FPR?
- Métricas:
 - M-DR4.1: $FPR (\%) = (n^{\circ} \text{ alertas falsas} / n^{\circ} \text{ alertas totales analizadas}) \times 100$.
 - M-DR4.2: FPR por fuente de alertas (SIEM, EDR, IDS, etc.).

G-DR4: *Reducir la tasa de falsos positivos a un nivel que no genere fatiga de analistas ni oculte incidentes reales.*

Q-DR4.1: ¿Qué porcentaje de alertas analizadas resulta ser falso positivo?

Q-DR4.2: ¿Cuál es la tendencia trimestral de la FPR?

Métricas:

3.2. Pilar Cobertura y Gestión de Vulnerabilidades — ACR, Tiempos de Remediación

3.2.1. ACR — Asset Coverage Ratio

- **G-CV1:** Asegurar que la práctica totalidad de los activos críticos está monitorizada y gestionada por el MSS, minimizando el "shadow IT" y las islas no supervisadas.
- **Q-CV1.1:** ¿Qué porcentaje de activos críticos figura en el inventario y está integrado en el sistema de monitorización?
- **Q-CV1.2:** ¿Cuál es la brecha entre activos inventariados y activos efectivamente monitorizados?
- **Métricas:**
 - M-CV1.1: $ACR \text{ global } (\%) = (n^{\circ} \text{ activos monitorizados} / n^{\circ} \text{ activos totales inventariados}) \times 100$.
 - M-CV1.2: ACR para activos críticos definidos como "tier 1".

G-CV1: *Asegurar que la práctica totalidad de los activos críticos está monitorizada y gestionada por el MSS, minimizando el "shadow IT" y las islas no supervisadas.*

Q-CV1.1: ¿Qué porcentaje de activos críticos figura en el inventario y está integrado en el sistema de monitorización?

Q-CV1.2: ¿Cuál es la brecha entre activos inventariados y activos efectivamente monitorizados?

Métricas:

3.2.2. Tiempo de Remediación de Vulnerabilidades Críticas

- G-CV2: Reducir el tiempo de parcheo de vulnerabilidades críticas por debajo de los umbrales recomendados (p.ej. 7-30 días) y del tiempo medio de explotación en la naturaleza.
- Q-CV2.1: ¿Cuál es el tiempo medio de remediación de vulnerabilidades con CVSS ≥ 9 ?
- Q-CV2.2: ¿Qué porcentaje de vulnerabilidades críticas permanece abierto más allá del umbral definido (p.ej. 30 días)?
- Métricas:
 - M-CV2.1: Tiempo medio de remediación (días) para CVEs críticas.
 - M-CV2.2: % de CVEs críticas abiertas >30 días.

G-CV2: *Reducir el tiempo de parcheo de vulnerabilidades críticas por debajo de los umbrales recomendados (p.ej. 7-30 días) y del tiempo medio de explotación en la naturaleza.*

Q-CV2.1: ¿Cuál es el tiempo medio de remediación de vulnerabilidades con CVSS ≥ 9 ?

Q-CV2.2: ¿Qué porcentaje de vulnerabilidades críticas permanece abierto más allá del umbral definido (p.ej. 30 días)?

Métricas:

3.3. Pilar Cumplimiento y Gobernanza — Conformidad ENS/NIS2/DORA, TPRM, MFA

La metodología GQM se aplica a indicadores como:

- Estado de conformidad ENS (por categoría de sistema).
- Estado de preparación NIS2 (brechas identificadas, acciones en curso).
- Existencia y eficacia del programa de gestión de riesgos de terceros (TPRM).
- Grado de implantación de MFA.

Ejemplo — **MFA universal (P6.3 de la encuesta):**

- G-GOV1: Garantizar que todos los accesos relevantes están protegidos por autenticación multifactor, tal como exige NIS2 Art. 21.2 j).
- Q-GOV1.1: ¿Qué porcentaje de usuarios dispone de MFA activado y requerido?
- Q-GOV1.2: ¿Qué flujos de autenticación carecen aún de MFA (aplicaciones legacy, accesos de terceros)?
- Métricas:
- % de cuentas con MFA obligatorio.
- N° de aplicaciones críticas sin MFA en todos sus flujos.

3.4. Pilar Financiero-Actuarial — ALE, ROSI y Ciberseguro

Ejemplo — **ROSI de MSS (ver Plantilla IGM/ROSI):**

- G-FIN1: Justificar económicamente la inversión en MSS demostrando reducción cuantificable del riesgo.
- Q-FIN1.1: ¿Cuánto perderíamos anualmente sin controles MSS (ALE_sin_controles)?
- Q-FIN1.2: ¿Cuánto perdemos con los controles MSS actuales (ALE_con_controles)?
-
- Q-FIN1.3: ¿Cuál es el payback de la inversión en MSS?
-
- Métricas:
- ALE_sin_controles, ALE_con_controles, Pérdidas_Evitadas.
- $ROSI (\%) = ((Pérdidas_Evitadas - Coste_MSS) / Coste_MSS) \times 100.$
- Payback (años).

Q-FIN1.3: ¿Cuál es el payback de la inversión en MSS?

Métricas:

3.5. Pilar Tecnologías Emergentes — Preparación PQC, IA, OT/ICS

Ejemplo — **Crypto-Agility Score (PQC):**

- G-EM1: Asegurar que los sistemas críticos pueden migrar a criptografía postcuántica sin rediseños traumáticos.
- Q-EM1.1: ¿Qué porcentaje de sistemas utiliza librerías criptográficas actualizables sin cambios estructurales?
- Q-EM1.2: ¿Cuántos sistemas críticos gestionan datos de larga vida con criptografía clásica vulnerable?

•
Métricas:

- % de sistemas con crypto-agility declarada.
- N^o de sistemas con datos de larga vida protegidos solo por RSA/ECC.

Q-EM1.2: ¿Cuántos sistemas críticos gestionan datos de larga vida con criptografía clásica vulnerable?

Métricas:

4. MATRIZ PRAGMATIC PARA CADA MÉTRICA CLAVE

Cada métrica propuesta se evalúa con la matriz PRAGMATIC. A modo de ejemplo, se presenta la valoración conceptual (de 0 a 10) para tres métricas emblemáticas: MTTD, ACR y ROSI.

4.1. Ejemplo 1 — MTTD (Mean Time to Detect)

Criterio PRAGMATIC	Evaluación conceptual	Comentario
P — Predictivo	9	Un MTTD bajo predice menor probabilidad de daño catastrófico; indicador fuertemente prospectivo.
R — Relevante	10	Directamente vinculado a cumplimiento NIS2 (plazos 24h/72h) y al coste de incidentes.
A — Accionable	9	Permite disparar acciones concretas (más analistas, tuning de reglas, IA, etc.).
G — Genuino	8	Si se instrumenta correctamente, se basa en datos exactos de time-stamping de alertas.
M — Significativo	9	Fácil de explicar al Consejo ("¿en cuánto tiempo nos enteramos?").
A — Preciso	8	Puede medirse con precisión de minutos; riesgo de sesgo si no se delimita bien "inicio".
T — Oportuno	8	Puede calcularse casi en tiempo real con SIEM/MDR bien configurado.
I — Independiente	7	Relativamente independiente, aunque incentivos de "maquillar" casos borde existen.
C — Rentable	8	Aprovecha datos ya disponibles en herramientas; coste incremental bajo.

4.2. Ejemplo 2 — ACR (Asset Coverage Ratio)

Criterio	Evaluación	Comentario
Predictivo	8	A mayor cobertura, menor probabilidad de incidentes no detectados.
Relevante	9	Directamente relacionado con el principio "no se puede proteger lo que no se ve".
Accionable	9	Sugiere acciones concretas: inventariar, desplegar agentes, integrar fuentes.
Genuino	7	Depende de la calidad del inventario; riesgo de infra/overestimar activos.
Significativo	8	Entendible por negocio: porcentaje de "superficie iluminada".
Preciso	7	Margen de error por activos efímeros o shadow IT, pero manejable.
Oportuno	7	Requiere actualización frecuente del inventario; automatización deseable.
Independiente	8	Menos susceptible de manipulación interesada, si se automatiza.
Rentable	7	Requiere inversión inicial en CMDB, pero bajo coste marginal posterior.

4.3. Ejemplo 3 — ROSI de MSS

Criterio	Evaluación	Comentario
Predictivo	8	Proyecta pérdidas evitadas futuras; depende de supuestos.
Relevante	10	Central para decisiones de inversión en seguridad.
Accionable	9	Permite priorizar medidas con mayor retorno.
Genuino	6	Sensible a supuestos; requiere transparencia en el modelo.
Significativo	9	Habla en euros, lenguaje natural del Consejo.
Preciso	6	Modelo probabilístico; precisión limitada por datos históricos.
Oportuno	7	Puede calcularse en ciclos presupuestarios (anual).
Independiente	6	Riesgo de sesgos al "afinar" supuestos para apoyar decisiones deseadas.
Rentable	8	Coste de cálculo bajo comparado con el valor de la información.

La **Matriz de Evaluación PRAGMATIC Completa** desarrolla esta tabla para todas las métricas candidatas, permitiendo seleccionar aquellas con mayor "metapuntuación" total.

5. ENCAJE CON GQM+Strategies: DEL OBJETIVO NACIONAL AL DATO DE LOG

El enfoque **GQM+Strategies** extiende GQM para enlazar explícitamente los objetivos de negocio con las estrategias y las métricas de nivel operativo[cite:129][cite:138]. Aplicado a MSS en España:

7. Nivel 0 — Objetivo nacional (político):
8. "Aumentar la resiliencia ciber de las infraestructuras esenciales españolas, reduciendo en un 50% el impacto de incidentes graves reportados a INCIBE en un horizonte de 5 años."
9. Nivel 1 — Objetivo organizacional (empresa concreta):
10. "Reducir el número y gravedad de incidentes críticos que afectan a nuestros servicios esenciales en un 30% en 3 años, cumpliendo NIS2/ENS."
11. Nivel 2 — Objetivo de servicio MSS:
12. "Reducir el MTDD de incidentes críticos a menos de 1 hora y el MTTR a menos de 24 horas antes de final de año."
13. Nivel 3 — Objetivo técnico:
14. "Optimizar reglas SIEM, despliegue EDR y procesos de escalado para incrementar en un 40% la proporción de incidentes detectados automáticamente."
15. Preguntas y métricas asociadas:
16. Q: ¿Cuál es el MTDD actual? — M: MTDD (min).
17. Q: ¿Qué porcentaje de incidentes se detecta automáticamente? — M: % detecciones automáticas.

Este encadenamiento permite trazar, por ejemplo, cómo un cambio en la configuración del SIEM (dato técnico) contribuye —a través de la reducción de MTDD— a los objetivos nacionales de resiliencia.

6. USO PRÁCTICO DEL MARCO GQM + PRAGMATIC EN EL CONTEXTO MSS

6.1. Proceso recomendado de diseño de indicadores

18. Identificar los objetivos estratégicos nacionales y organizacionales (Goals G0.x, G-DRx, G-CVx, etc.).
19. Derivar preguntas concretas (Questions) que evidencien el grado de consecución de cada objetivo.
20. Proponer un conjunto inicial de métricas (Metrics) por pregunta, basadas en datos accesibles.
21. Evaluar cada métrica candidata con el marco PRAGMATIC (0-10 por criterio).
22. Seleccionar aquellas métricas que superen un umbral PRAGMATIC total (p.ej. $\geq 60/90$) y no suspendan en más de 2 criterios clave (Predictivo, Relevante, Accionable).
23. Integrar las métricas seleccionadas en los SLAs MSS, los cuadros de mando y los informes a la Alta Dirección.
24. Revisar anualmente el conjunto de métricas a la luz de cambios tecnológicos, de amenaza y regulatorios.

6.2. Relación con la Encuesta MSS

El marco GQM + PRAGMATIC se integra de la siguiente forma con la Encuesta MSS y el IGM-MSS:

- Cada pregunta de la encuesta se asocia a uno o varios Goals y Questions GQM (ver documento de mapeo normativo y GQM específico).
- Cada métrica técnica (MTDD, MTTR, ACR, ROSI, etc.) tiene su ficha GQM y su ficha PRAGMATIC.
- El IGM-MSS se construye a partir de métricas que han superado el filtro PRAGMATIC, asegurando que el índice no sea un promedio de números arbitrarios.

7. CONCLUSIÓN

El marco integrativo GQM + PRAGMATIC convierte el problema nebuloso de "¿qué deberíamos medir?" en un proceso disciplinado y trazable:

- GQM asegura que cada métrica responde a preguntas que, a su vez, derivan de objetivos explícitos.
- PRAGMATIC asegura que las métricas elegidas no solo sean conceptualmente correctas, sino útiles en la práctica, evitables de sesgos evidentes y razonables en coste.

En un contexto en el que España ha multiplicado su inversión en ciberseguridad, se enfrenta a una presión regulatoria creciente y forma parte de un mercado MSS con fuerte dependencia de proveedores no-UE, disponer de un marco sólido para diseñar y seleccionar métricas deja de ser un lujo metodológico: se convierte en un requisito de supervivencia estratégica.

Marco Integrativo GQM + PRAGMATIC — Versión 1.0 · Abril 2026

Basado en: Basili & Weiss (Goal–Question–Metric)[cite:129][cite:138][cite:141], PRAGMATIC Security Metrics (Brotby & Hinson)[cite:130][cite:131][cite:136][cite:142], The Smart Approach to Selecting Good Cyber Security Metrics (2024)[cite:139], aplicaciones GQM a ciberseguridad[cite:134].